EXPEDIENTE CLINICO ELECTRONICO

Reglas de negocio

Taller III - sistema clinico para clinicas pequenas y policonsultorios

Producto Savia ECE	**Revision** 2.0 - 14 de octubre de 2026
Arquitectura React, Express, Prisma y PostgreSQL	**Alcance** Acceso, expediente, SOAP, citas, recetas y auditoria

Proposito

Este documento define las reglas verificables de Savia ECE despues de integrar autenticacion, pacientes, agenda, notas SOAP, adendas, recetas y auditoria. Cada regla indica el comportamiento esperado del sistema y separa los controles implementados de las integraciones externas pendientes.

Alcance regulatorio
La alineacion declarada con NOM-004-SSA3-2012 y NOM-024-SSA3-2012 describe decisiones tecnicas del proyecto. No representa certificacion, dictamen juridico ni firma electronica avanzada.

1. Acceso, usuarios y expediente

RN-01	**Roles institucionales** El sistema admite ADMINISTRADOR, MEDICO_GENERAL, MEDICO_ESPECIALISTA, ENFERMERIA y RECEPCION. Toda autorizacion se resuelve en el servidor.
RN-02	**Autenticacion real** El acceso requiere correo y contrasena bcrypt. El servidor emite un JWT y verifica en cada solicitud que la cuenta exista y permanezca activa.
RN-03	**Administracion segura** Solo ADMINISTRADOR puede consultar o crear usuarios. La baja es logica; desactiva la cuenta sin eliminar su historial y un administrador no puede desactivarse a si mismo.
RN-04	**Identificacion del paciente** Cada paciente requiere folio unico. La CURP es opcional, pero si se registra tambien debe ser unica.
RN-05	**Conservacion del expediente** La baja del paciente se modela mediante deleted_at. Las consultas operativas excluyen registros dados de baja y no destruyen las referencias clinicas.
RN-06	**Minimo privilegio** Recepcion gestiona directorio y citas sin leer datos clinicos. Enfermeria consulta el expediente y captura signos vitales. Solo personal medico crea, firma, agrega adendas y prescribe.

2. Datos sensibles y signos vitales

RN-07	**Proteccion de la llave** El servidor no inicia el adaptador criptografico sin CLINICAL_FLE_MASTER_KEY de 32 bytes expresada como 64 caracteres hexadecimales.
RN-08	**Cifrado de antecedentes** Alergias y antecedentes heredofamiliares, patologicos, no patologicos y gineco-obstetricos se modelan con ciphertext, IV y tag independientes.
RN-09	**Signos vitales completos** Cada captura conserva peso, talla, IMC, presion arterial, frecuencias cardiaca y respiratoria, temperatura, saturacion, glucosa opcional, notas, paciente y autor.
RN-10	**Validacion fisiologica** El servidor rechaza valores fuera de los rangos aceptados. El IMC se calcula con peso / talla al cuadrado y se almacena con la captura.

3. Nota clinica SOAP

RN-11	**Estado inicial** Toda nota se crea en BORRADOR y conserva paciente, medico, fecha y diagnostico principal.
RN-12	**Contenido minimo** Subjetivo, Objetivo, Analisis y Plan son obligatorios y deben superar la longitud minima. El CIE-10 principal es obligatorio y admite codigos secundarios.
RN-13	**Relaciones validas** Antes de cifrar, el servidor comprueba que paciente y medico esten activos. Si se asocian signos vitales, deben existir y pertenecer al mismo paciente.
RN-14	**Cifrado FLE** Los cuatro campos SOAP se cifran individualmente con AES-256-GCM y un IV unico de 12 bytes.
RN-15	**Integridad criptografica** El descifrado valida la etiqueta GCM. Una alteracion de ciphertext, IV, tag o llave detiene la lectura por violacion de integridad.
RN-16	**Trazabilidad al crear** La creacion registra RECORD_CREATE con usuario, paciente, recurso, IP, agente de usuario y diagnostico principal.
RN-17	**Lectura autorizada** El historial se descifra en el servidor solo para roles clinicos autorizados; los datos cifrados no se entregan directamente a la interfaz.

4. Firma, inmutabilidad y adendas

RN-18	**Autor y cedula** Solo el medico autor puede firmar la nota y debe tener cedula profesional registrada.
RN-19	**Firma unica** Solo una nota BORRADOR puede firmarse. Una nota FIRMADA o ANULADA_POR_ADENDA no puede firmarse nuevamente.
RN-20	**Sello de integridad** La firma genera un SHA-512 con identidad de nota, paciente, medico, cedula, fecha de creacion y contenido cifrado; tambien conserva signed_at.
RN-21	**Inmutabilidad** La firma cambia el estado a FIRMADA. Los campos clinicos originales no se editan despues de la firma.
RN-22	**Adenda aclaratoria** Solo el autor puede agregar una adenda a una nota firmada vigente. Se crea una nueva nota firmada enlazada por parent_consultation_id, se marca la original y se registra RECORD_ADDENDA.

5. Agenda y flujo de atencion

RN-23	**Datos de la cita** Una cita relaciona paciente, medico, fecha, duracion de 10 a 240 minutos, motivo opcional y estado operativo.
RN-24	**Fecha futura** Una nueva cita no puede programarse en el pasado.
RN-25	**Conflicto exacto** El sistema impide dos citas activas para el mismo medico en la misma fecha y hora. CANCELADA y NO_ASISTIO no bloquean el horario.
RN-26	**Estados permitidos** PROGRAMADA, CONFIRMADA, EN_SALA_DE_ESPERA, EN_CONSULTA, COMPLETADA, CANCELADA y NO_ASISTIO son los unicos estados validos.
RN-27	**Alcance por rol** Los medicos visualizan y modifican su propia agenda. Recepcion y administracion pueden coordinar citas institucionales; enfermeria actualiza el flujo de atencion.

6. Receta digital y verificacion

RN-28	**Origen clinico** Una receta solo puede emitirse desde una nota FIRMADA y por el medico autor de esa nota.
RN-29	**Una receta por consulta** consultation_id es unico. Una misma nota no puede producir recetas duplicadas.
RN-30	**Contenido y vigencia** La receta requiere al menos un medicamento con presentacion, dosis, frecuencia, duracion y via; las indicaciones se cifran y la expiracion debe ser futura.
RN-31	**QR unico** Cada receta recibe un codigo aleatorio unico persistido en PostgreSQL. El QR codifica la ruta de verificacion real del sistema.
RN-32	**Privacidad al verificar** La pagina publica solo confirma vigencia, profesional, cedula y fecha limite. No revela paciente, diagnostico, medicamentos ni indicaciones.

7. Auditoria e integridad operativa

RN-33	**Eventos auditables** Se registran accesos, lecturas, creaciones, firmas, adendas, recetas, adjuntos e intentos de acceso no autorizado.
RN-34	**Cadena SHA-256** Cada evento usa el hash anterior, los datos normalizados y un timestamp conservado en details_json. El primer eslabon parte de GENESIS_HEALTH_HASH.
RN-35	**Concurrencia serializada** La escritura de auditoria toma un bloqueo transaccional consultivo de PostgreSQL antes de leer el ultimo hash e insertar el siguiente eslabon.
RN-36	**Visibilidad administrativa** El visor de trazabilidad solo esta disponible para ADMINISTRADOR y limita la consulta a los eventos recientes.

8. Estado de hallazgos de la revision anterior

A-01	Autenticacion simulada	**RESUELTO**	JWT, bcrypt e identidad verificada contra usuario activo.
A-02	API de usuarios sin RBAC	**RESUELTO**	Rutas administrativas protegidas; alta segura y baja logica.
A-03	Validacion clinica	**RESUELTO**	Zod, rangos y comprobacion de relaciones paciente-medico-vitales.
A-04	Adendas	**RESUELTO**	Endpoint real, relacion de origen, firma y RECORD_ADDENDA.
A-05	UI simulada	**RESUELTO**	Pacientes, SOAP, agenda, receta y auditoria consumen API persistente.
A-06	Firma avanzada	**PENDIENTE EXTERNO**	El SHA-512 aporta integridad; falta proveedor de firma avanzada y validacion oficial de cedula.
A-07	Auditoria concurrente	**RESUELTO**	Bloqueo advisory dentro de transaccion PostgreSQL.
A-08	QR ilustrativo	**RESUELTO**	Codigo persistido, expiracion y pagina publica de verificacion minima.

Pendientes para una operacion real

La siguiente etapa no debe ocultarse bajo una etiqueta de terminado: firma electronica avanzada y validacion oficial de cedula; almacenamiento S3 con politicas de retencion; automatizaciones n8n/Telegram; recuperacion y rotacion segura de llaves; pruebas de concurrencia y penetracion; respaldo, monitoreo, acuerdos de privacidad y revision juridico-regulatoria.

Criterio de aceptacion

Las compilaciones de backend y frontend deben finalizar sin errores; las pruebas AES-256-GCM deben conservar 3/3 casos aprobados; los endpoints protegidos deben responder 401 sin identidad y 403 cuando el rol no sea suficiente; ningun modulo debe mostrar datos clinicos simulados como si fueran persistidos.